COMPTIA SECURITY+ SY0-701 DOMÍNIO 5 · GESTÃO DE PROGRAMA DE SEGURANÇA E GOVERNANÇA (20%)

Security+ 5.1 · Security Considerations

Mestre CyberSec · **Aula 5.1 — Security Considerations** (4:51) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Regulatório: GDPR (UE), HIPAA (saúde US), PCI-DSS (cartão), SOX (financeiro público), FERPA (educacional); legal issues (evidência, privacidade, investigação); industry standards (CIS, ISO, NIST).

💡 Highlights que a prova CompTIA cobra

- Cada indústria tem sua LEI: PCI-DSS pagamento, HIPAA saúde, SOX financeiro
- GDPR protege dados de UE-cidadãos INDEPENDENTE de onde a empresa está

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'regulation protecting EU citizen data'=GDPR

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 5.1 — Security Considerations)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Regulamento Geral de Proteção de Dados (GDPR)

Regulamento da UE que protege dados pessoais de cidadãos/residentes da UE e se aplica a organizações em qualquer lugar que processem esses dados.

⚠️ ***Armadilha CompTIA:*** *Questão citando 'dados de cidadãos da UE independente da localização da empresa' = GDPR.*

• Lei de Portabilidade e Responsabilidade de Seguros de Saúde (HIPAA)

Lei dos EUA que protege informações de saúde (PHI) e exige salvaguardas de privacidade e segurança na área de saúde.

⚠️ ***Armadilha CompTIA:*** *Saúde, PHI, hospital ou seguradora nos EUA = HIPAA.*

• Padrão de Segurança de Dados da Indústria de Cartões de Pagamento (PCI-DSS)

Padrão da indústria para organizações que armazenam, processam ou transmitem dados de titulares de cartão, com requisitos para proteger dados de cartões.

⚠️ ***Armadilha CompTIA:*** *Dados de cartão de crédito/débito = PCI-DSS; é padrão da indústria, não lei governamental.*

• Lei Sarbanes-Oxley (SOX)

Lei dos EUA que impõe requisitos de relatórios financeiros, controles internos e retenção de registros a empresas de capital aberto.

⚠️ ***Armadilha CompTIA:*** *Empresa de capital aberto, relatórios financeiros ou controles internos = SOX.*

• Lei de Direitos e Privacidade Educacionais da Família (FERPA)

Lei dos EUA que protege a privacidade de registros educacionais de estudantes em instituições que recebem financiamento federal.

⚠️ ***Armadilha CompTIA:*** *Registros acadêmicos, escola/universidade ou aluno = FERPA.*

• Centro para Segurança na Internet (CIS)

Organização que publica os Controles e Benchmarks CIS, boas práticas priorizadas de segurança para endurecer sistemas e reduzir risco cibernético.

⚠️ ***Armadilha CompTIA:*** *Controles priorizados, benchmarks de configuração ou hardening = CIS.*

• Organização Internacional de Normalização (ISO)

Organismo internacional de normas; ISO/IEC 27001/27002 definem requisitos e orientações para sistemas de gestão de segurança da informação e controles.

⚠️ ***Armadilha CompTIA:*** *Padrão internacional, SGSI ou ISO 27001/27002 = ISO.*

• Instituto Nacional de Padrões e Tecnologia (NIST)

Agência dos EUA que publica frameworks e diretrizes de segurança cibernética, como o NIST Cybersecurity Framework e a SP 800-53.

⚠️ ***Armadilha CompTIA:*** *Framework dos EUA, RMF, CSF ou SP 800-53 = NIST; frequentemente usado como padrão voluntário.*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um varejista online europeu descobre que um ex-funcionário na Alemanha ainda tem acesso a registros de clientes contendo nomes, endereços e histórico de compras. A equipe de segurança deve reportar a potencial exposição de dados pessoais de cidadãos da UE em 72 horas. Qual framework regulatório impõe especificamente esse prazo de notificação?

A) Regra de Notificação de Violação do HIPAA

B) Requisito 12.10 do PCI-DSS

C) Artigo 33 do GDPR

D) Seção 404 do SOX

QUESTÃO 2 · CENÁRIO DE EXAME

O administrador de TI de um hospital está implementando controles para proteger Informações de Saúde Eletrônicas Protegidas (ePHI) armazenadas em um novo servidor de arquivos. Ele precisa garantir a confidencialidade, integridade e disponibilidade dos dados de saúde. Qual regulação federal dos EUA define essas garantias específicas?

A) Lei Sarbanes-Oxley (SOX)

B) Regra de Segurança do Health Insurance Portability and Accountability Act (HIPAA)

C) Padrão de Segurança de Dados da Indústria de Cartões de Pagamento (PCI-DSS)

D) Lei de Direitos Educacionais e Privacidade Familiar (FERPA)

QUESTÃO 3 · CENÁRIO DE EXAME

Uma pequena empresa de e-commerce processa aproximadamente 500 transações de cartão de crédito por mês e armazena os dados do titular em um arquivo de banco de dados simples. Um consultor de segurança deve recomendar o padrão que define como esses dados devem ser protegidos durante armazenamento e transmissão. Qual framework de conformidade se aplica?

A) GDPR

B) PCI-DSS (Padrão de Segurança de Dados da Indústria de Cartões de Pagamento)

C) SOX

D) FERPA

QUESTÃO 4 · CENÁRIO DE EXAME

O CFO de uma empresa de capital aberto está preocupado com a precisão das demonstrações financeiras enviadas à SEC. A equipe de segurança de TI deve implementar controles garantindo a integridade dos sistemas de relatórios financeiros e trilhas de auditoria. Qual regulação rege diretamente esses requisitos para empresas públicas?

A) HIPAA

B) PCI-DSS

C) Seção 404 da Lei Sarbanes-Oxley (SOX)

D) Artigo 32 do GDPR

QUESTÃO 5 · CENÁRIO DE EXAME

Uma universidade sofre uma violação de dados em que um invasor acessa registros de estudantes incluindo notas, arquivos disciplinares e números de Seguro Social. Os pais exigem saber por que os registros educacionais de seus filhos não foram protegidos. Qual regulação dos EUA rege especificamente a proteção de registros educacionais de estudantes?

A) Regra de Privacidade do HIPAA

B) Lei de Direitos Educacionais e Privacidade Familiar (FERPA)

C) PCI-DSS

D) SOX

QUESTÃO 6 · CENÁRIO DE EXAME

Uma corporação multinacional está adotando um framework de segurança que fornece orientação priorizada, acionável e prescritiva para mitigação de riscos cibernéticos. O CISO deseja um framework que mapeie controles de segurança para níveis de implementação específicos baseados na maturidade organizacional. Qual framework do setor melhor atende a esse requisito?

A) GDPR

B) Controles Críticos de Segurança CIS (CIS Controls)

C) HIPAA

D) PCI-DSS

QUESTÃO 7 · CENÁRIO DE EXAME

Uma organização está buscando certificação ISO para demonstrar aos clientes europeus que seu Sistema de Gestão de Segurança da Informação (SGSI) segue as melhores práticas reconhecidas internacionalmente. O auditor avaliará a abordagem sistemática da empresa no tratamento de informações sensíveis. Qual norma ISO aborda especificamente um SGSI?

A) ISO 27002

B) ISO 27005

C) ISO 31000

D) ISO 9001

QUESTÃO 8 · CENÁRIO DE EXAME

Uma agência federal dos EUA deve adotar um framework comum para melhorar a cibersegurança de infraestruturas críticas. O CIO publicou orientações que integram padrões do setor, normas e melhores práticas para ajudar organizações a gerenciar riscos de cibersegurança. Qual publicação do NIST fornece esse framework abrangente de cibersegurança?

A) NIST SP 800-53

B) NIST SP 800-37 (Risk Management Framework)

C) Framework de Cibersegurança do NIST (CSF)

D) NIST SP 800-30

QUESTÃO 9 · CENÁRIO DE EXAME

Um investigador forense chega a uma cena de crime onde um servidor contém potenciais evidências de fraude financeira. O investigador nota que o servidor ainda está em execução e conectado à rede. Para preservar a integridade e admissibilidade da evidência, qual é a ação MAIS apropriada a ser tomada primeiro?

A) Desligar imediatamente o servidor para parar todos os processos em execução

B) Conectar um drive externo e copiar todos os arquivos imediatamente

C) Documentar o estado do sistema e capturar a memória volátil antes de desligar

D) Restaurar o sistema a partir do backup mais recente

QUESTÃO 10 · CENÁRIO DE EXAME

Um analista de marketing em uma multinacional recebe uma solicitação de um cliente alemão para excluir todas as informações pessoais que a empresa coletou sobre ele, incluindo histórico de navegação, registros de compras e correspondência por e-mail. Qual regulação concede ao cliente esse direito específico?

A) Direito ao Apagamento do PCI-DSS

B) Direito ao Esquecimento do HIPAA

C) Direito ao Apagamento do GDPR (Artigo 17)

D) Direito à Exclusão do SOX

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Artigo 33 do GDPR

O Artigo 33 do GDPR exige que a autoridade supervisora seja notificada sobre uma violação de dados pessoais em até 72 horas após tomar conhecimento. O HIPAA aplica-se à saúde dos EUA, o PCI-DSS aos dados de cartão, e o SOX aos controles de relatórios financeiros. A jurisdição da UE e a janela de 72 horas no cenário são elementos característicos do GDPR.

Questão 2: Alternativa B — Regra de Segurança do Health Insurance Portability and Accountability Act (HIPAA)

A Regra de Segurança do HIPAA (45 CFR Parte 160 e Subpartes A e C da Parte 164) estabelece padrões nacionais para proteger ePHI. Ela exige salvaguardas administrativas, físicas e técnicas garantindo confidencialidade, integridade e disponibilidade (a tríade do CID). O SOX abrange relatórios financeiros, o PCI-DSS abrange dados de cartão e a FERPA abrange registros educacionais de estudantes.

Questão 3: Alternativa B — PCI-DSS (Padrão de Segurança de Dados da Indústria de Cartões de Pagamento)

O PCI-DSS aplica-se a qualquer entidade que armazene, processe ou transmita dados de titulares de cartão, independentemente do volume de transações. O padrão define requisitos para transmissão criptografada, controle de acesso e armazenamento seguro do Número de Conta Primário (PAN). O GDPR abrange dados pessoais da UE amplamente, o SOX abrange relatórios financeiros e a FERPA abrange registros de estudantes.

Questão 4: Alternativa C — Seção 404 da Lei Sarbanes-Oxley (SOX)

A Seção 404 do SOX exige que empresas públicas estabeleçam controles internos e procedimentos para relatórios financeiros, incluindo controles gerais de TI que garantem a integridade dos sistemas que produzem dados financeiros. A Seção 802 especificamente exige a retenção de registros relacionados à auditoria por sete anos. HIPAA, PCI-DSS e GDPR não abordam a integridade de demonstrações financeiras para empresas públicas.

Questão 5: Alternativa B — Lei de Direitos Educacionais e Privacidade Familiar (FERPA)

A FERPA (20 U.S.C. § 1232g) protege a privacidade dos registros educacionais dos estudantes, concedendo aos pais certos direitos sobre acesso e divulgação de informações pessoalmente identificáveis desses registros. Aplica-se a todas as escolas que recebem auxílio federal. A menção no cenário a registros de estudantes (notas, arquivos disciplinares) é um cenário clássico de FERPA, distinguindo-o de regulamentações de saúde (HIPAA) ou financeiras.

Questão 6: Alternativa B — Controles Críticos de Segurança CIS (CIS Controls)

Os Controles Críticos de Segurança do CIS (anteriormente SANS Top 20) fornecem um conjunto priorizado de ações organizadas em Grupos de Implementação (IG1, IG2, IG3) com base no tamanho e maturidade organizacional. O framework é amplamente adotado como um padrão prescritivo de cibersegurança. GDPR e HIPAA são regulamentações com requisitos de conformidade, e o PCI-DSS foca apenas em dados de cartão de pagamento.

Questão 7: Alternativa A — ISO 27002

A ISO/IEC 27002 fornece o código de prática para controles de segurança da informação e é comumente usada em conjunto com a ISO 27001 para implementação do SGSI. Observação: a ISO 27001 especifica os requisitos do SGSI, mas a ISO 27002 (originalmente ISO 17799) fornece o catálogo detalhado de controles. A ISO 27005 foca na metodologia de gestão de riscos, a ISO 31000 é gestão de riscos corporativos e a ISO 9001 é gestão da qualidade. A resposta mais precisa entre as alternativas é ISO 27002 para os controles.

Questão 8: Alternativa C — Framework de Cibersegurança do NIST (CSF)

O Framework de Cibersegurança do NIST (CSF) fornece um framework político de orientação de segurança computacional sobre como organizações do setor privado podem avaliar e melhorar sua capacidade de prevenir, detectar e responder a ataques cibernéticos. As funções centrais do CSF são Identificar, Proteger, Detectar, Responder e Recuperar. O NIST SP 800-53 é o catálogo de controles para sistemas federais, o SP 800-37 é o RMF e o SP 800-30 é orientação para avaliação de riscos.

Questão 9: Alternativa C — Documentar o estado do sistema e capturar a memória volátil antes de desligar

O procedimento forense adequado requer seguir a ordem de volatilidade: capturar primeiro a memória volátil (RAM, conexões de rede, processos em execução), depois documentar o estado do sistema e só então considerar o desligamento controlado. Desligar imediatamente destrói evidências voláteis como processos em execução, conexões de rede e conteúdo da memória. O investigador também deve manter a cadeia de custódia e usar bloqueadores de escrita para imagem do disco.

Questão 10: Alternativa C — Direito ao Apagamento do GDPR (Artigo 17)

O Artigo 17 do GDPR estabelece o 'Direito ao Apagamento' (também chamado 'Direito ao Esquecimento'), permitindo que titulares de dados da UE solicitem a exclusão de seus dados pessoais quando certas condições são atendidas (por exemplo, dados não são mais necessários para o propósito original, consentimento retirado). PCI-DSS, HIPAA e SOX não concedem aos consumidores tais direitos de exclusão sobre seus dados. Apenas o GDPR fornece esse direito específico entre as opções listadas.